用 AI 安全平台扫了一遍 Qwen2.5：OWASP LLM Top 10 实测笔记

漏洞挖掘 · VULNHUNT × AI 安全

用 AI 安全平台扫了一遍 Qwen2.5：OWASP LLM Top 10 实测笔记

有人用自研的 AI 安全平台，把 Qwen2.5-7B 按 OWASP LLM Top 10 跑了一遍：**102 项测试、42 个漏洞、命中率 47.7%**。近一半主流开源模型挡不住一套"基础 AI 安全测试"——这句话听着刺耳，但实测数据摆在那。这篇把这份公开复盘拆开看，只做技术事实陈述。

> 所有数据来自看雪公开帖（thread-293107 / 293081 / 293072）的实测复盘；本文只引用其结论与方法，不提供任何可用于攻击的载荷或利用链。

01 它是什么：把 OWASP 清单变成可执行用例

平台叫 `ai-security-agent-platform`（GitHub 1ouxilisi，FastAPI，MIT）。它的价值不在"又做了一个聊天机器人"，而在把 **OWASP LLM Top 10** 从一份检查清单，变成了可以自动跑的测试用例集——输出处理、过度代理、提示注入、越狱、供应链，逐项打。

方法论本身比单个数字更值得抄：先有标准化测试集，再有可复现的命中率，最后才是"哪个模型更稳"的结论。

02 数据：102 项测试，命中 47.7%

整体：**102 项测试 / 42 个漏洞 / 命中率 47.7%**。分类型看更说明问题：

风险类型	命中率

输出处理不当（LLM05）	100%
过度代理（LLM06）	73%
系统提示词泄露（LLM07）	67%
提示注入（LLM01）	39%
越狱（Jailbreak）	仅 7%

越狱命中最低，不等于最安全——它只说明"硬撬"难，而前面几项才是真实敞口：输出不处理、代理权限过大、提示词随手可套。

03 三个刺眼的点

1. **系统提示词直接套出**：部分国产模型在诱导下自报了不该说的身份标识，出现身份混淆。
2. **供应链持久化注入单轮即服从**：一段藏在依赖里的指令，一次交互就被模型照做。
3. **输出回显敏感 payload**：模型把本应被过滤的内容原样回显，暴露后端处理链。

04 别神话：覆盖率只有 23%

同一平台去扫 OWASP Juice Shop（一个故意留洞的练习应用），自动化只覆盖到约 **23%**。它能初筛出信息收集、注入类敞口，但复杂的业务逻辑漏洞——需要"理解业务才能看出不对劲"的那类——仍要靠人工。

一句话边界：**AI 渗透的价值在初筛自动化，替代不了人工逻辑测试**。把自动化当第一遍扫描，把人留给真正要动脑子的地方。

05 红队进化：从 12% 到 86.3%

另一组公开实验用遗传算法进化了 **24000 种 Prompt 注入**：第一代直接注入命中 12%，迭代五代后最优组合达到 **86.3%**——手法是 Base64 编码 → 翻译任务 → 角色扮演 + 编码递进。攻击者也在用进化算法卷。

防守侧对应的五层：输入解码检测 / 对话多轮检测 / 输出敏感过滤 / Agent 工具白名单 / 红队常态化。攻防都在自动化，差别只在谁先把它当工程做。

参考来源

看雪论坛 bbs.kanxue.com — thread-293107（Qwen2.5-7B OWASP LLM Top 10 实测）

看雪论坛 bbs.kanxue.com — thread-293081（AI 平台扫 OWASP Juice Shop）

看雪论坛 bbs.kanxue.com — thread-293072（遗传算法进化 24000 种 Prompt 注入）

OWASP Top 10 for LLM Applications 2025